

LAB 09

DAY 13

Calculating & Contextualizing Risk Scores

Using CVSS v3.x — CVE Analysis & Environmental Adjustment

COURSE: Managing Vulnerabilities
STUDENT: HASSANI Mohammad Salem
INSTRUCTOR: Asen Grozdanov
DATE: February 28, 2026
CLASSIFICATION: Educational Use Only

PART 1 — Reading and Decomposing a Base Score

1.1 CVE Overview

CVE-2021-44228**Log4Shell****10.0 CRITICAL**

CVE-2021-44228 (Log4Shell) affects Apache Log4j 2 and allows **remote code execution** without authentication or user interaction. It is one of the most severe vulnerabilities ever discovered, with a CVSS v3.1 Base Score of **10.0 (Critical)** as assigned by NVD.

1.2 Base Score Decoding

CVSS v3.1 Vector String:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Metric	Code	Value	Meaning
Attack Vector	AV:N	Network	Exploitable remotely over the network
Attack Complexity	AC:L	Low	No special conditions required
Privileges Required	PR:N	None	No authentication required
User Interaction	UI:N	None	No user action needed
Scope	S:C	Changed	Compromise impacts other components
Confidentiality Impact	C:H	High	Full data disclosure
Integrity Impact	I:H	High	Full data modification
Availability Impact	A:H	High	Complete service disruption

Reflection:

This vulnerability reaches the maximum score because it is remotely exploitable, requires no authentication or user interaction, and results in full compromise of confidentiality, integrity, and availability. The **Changed Scope** further amplifies its impact by affecting components beyond the vulnerable system, justifying a Base Score of 10.0.

1.3 Base Score Verification

The Base metrics were manually entered into the CVSS v3.1 calculator and successfully reproduced a Base Score of 10.0.

Subscore	Value
----------	-------

Impact Subscore	6.0
Exploitability Subscore	3.9
CVSS Base Score	10.0
CVSS Temporal Score	N/A (Part 1 only)
CVSS Environmental Score	N/A (Part 1 only)
Overall CVSS Score	10.0

PART 2 — Temporal and Environmental Adjustments (SecureMart Scenario)

2.1 Temporal Metrics — SecureMart Scenario

Temporal Metric	Code	Selected Value	Rationale
Exploit Code Maturity	E:H	High	Weaponized exploit widely available in the wild
Remediation Level	RL:W	Workaround	Vendor patch not yet released; mitigation available
Report Confidence	RC:C	Confirmed	Vulnerability confirmed by NVD and CISA
CVSS TEMPORAL SCORE	9.7 — Critical		

2.2 Environmental Metrics — SecureMart Scenario

Organizational Context — SecureMart Inc.:

- Internal inventory management system — not publicly accessible
- Accessible only via VPN — reduces network-level attack surface
- Non-sensitive operational data — lower confidentiality requirements
- Egress filtering and SIEM monitoring deployed
- Patch scheduled for deployment

Environmental Metric	Code	Value	Justification
Confidentiality Requirement	CR:L	Low	Non-sensitive data; data exposure impact is limited
Integrity Requirement	IR:M	Medium	Operational data; some integrity impact if modified
Availability Requirement	AR:H	High	Inventory system critical for operations
Modified Attack Vector	MAV:A	Adjacent	VPN-only access limits remote network exploitability

Modified Attack Complexity	MAC : H	High	VPN + SIEM adds detection/prevention layers
CVSS ENVIRONMENTAL SCORE (SecureMart)	8.2 — High		

2.3 Comparative Analysis — Score Progression

Score Type	Value	Severity	Change	Key Factor
Base Score	10.0	Critical	—	Technical severity of the vulnerability itself
Temporal Score	9.7	Critical	▼ 0.3	Active exploits + workaround only
Environmental Score	8.2	High	▼ 1.5	VPN access + non-sensitive data + SIEM

2.4 Alternate Scenario — Hospital Environment

In a hospital scenario, the same CVE-2021-44228 vulnerability would carry a significantly higher environmental score due to the critical nature of healthcare systems.

Factor	SecureMart (Completed)	Hospital (Alternate)
System Exposure	VPN-only	Internet-facing
Workaround	Available	None
Confidentiality Req.	Low	High — patient data
Integrity Requirement	Medium	High — clinical records
Availability Requirement	High	High — life-critical
Expected Env. Score	8.2 (High)	~10.0 (Critical)

 **Key Insight:** This comparison demonstrates the fundamental limitation of vendor Base Scores: the same vulnerability can represent vastly different risk levels depending on organizational context. Environmental adjustment is essential for accurate risk prioritization.

PART 3 — Second Vulnerability Analysis (CVE-2019-2989)

3.1 Selected CVE Overview

CVE-2019-2989	Oracle Java SE	6.8 MEDIUM
---------------	----------------	------------

Attribute	Details
Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:N/I:H/A:N
Impact	Integrity — allows unauthorized creation, deletion, or modification of data
Affected	Java SE 7u231, 8u221, 11.0.4, 13; Java SE Embedded 8u221
Exploitability	Difficult — requires network access via multiple protocols

3.2 Organizational Context

The affected system is an internal Java-based web service used for processing supplier data. It is not internet-facing and processes non-sensitive operational data. Firewall and endpoint security controls are in place.

Factor	Value
System Type	Internal Java web service — supplier data processing
Internet Facing	No — internal network only
Data Sensitivity	Non-sensitive operational data
Controls in Place	Firewall + endpoint security
Confidentiality Priority	Low
Integrity Priority	High — data accuracy is critical
Availability Priority	Medium

3.3 CVSS Calculation and Justification

Temporal Metrics:

Metric	Code	Value	Justification
Exploit Code Maturity	E:F	Functional	Functional exploit code exists and is reliable
Remediation Level	RL:O	Official Fix	Oracle released an official patch
Report Confidence	RC:C	Confirmed	NVD-confirmed vulnerability

Environmental Metrics:

Metric	Code	Value	Justification
Confidentiality Requirement	CR:L	Low	Non-sensitive data — low impact if disclosed
Integrity Requirement	IR:H	High	Supplier data accuracy is business-critical

Availability Requirement	AR:M	Medium	Service downtime has moderate business impact
Modified Attack Vector	MAV:A	Adjacent	Internal network only; not internet-facing
Modified Attack Complexity	MAC:H	High	Firewall + endpoint controls increase difficulty
Modified Integrity Impact	MI:H	High	Reflects high IR weight on integrity outcomes

Score Type	Value	Severity
CVSS Base Score	6.8	Medium
CVSS Temporal Score	6.3	Medium
CVSS Environmental Score	7.6	High
Overall CVSS Score	7.6	High

Notable Finding: CVE-2019-2989 starts with a Medium Base Score (6.8) but its Environmental Score rises to High (7.6) due to the critical importance of data integrity in the supplier workflow. This demonstrates that even Medium-rated CVEs can demand urgent remediation in specific contexts.

Final Conclusion

This lab demonstrates that **CVSS Base Scores represent technical severity rather than organizational risk**. Applying Temporal and Environmental metrics allows vulnerabilities to be prioritized based on real-world business impact and operational context.

CVE	Base	Temporal	Environmental	Org. Context
CVE-2021-44228 (Log4Shell)	10.0 Critical	9.7 Critical	8.2 High	SecureMart: VPN-only, non-sensitive data, SIEM monitoring
CVE-2021-44228 (Log4Shell)	10.0 Critical	—	~10.0 Critical	Hospital (alternate): internet-facing, patient data, no workarounds
CVE-2019-2989 (Oracle Java SE)	6.8 Medium	6.3 Medium	7.6 High	Internal Java service: supplier data, high integrity requirements

KEY FINDING

Base Scores alone are insufficient for risk prioritization. Temporal metrics capture exploit availability and remediation status, while Environmental metrics translate technical severity into organizational impact. The same vulnerability (CVE-2021-44228) carries 10.0 in a hospital but 8.2 in SecureMart — context defines risk.